LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

Daily 2026-10-25 Nextcloud Collabora CODE CVE-2026-110447 Exploitation Priority Update

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-10-25
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

Published: 2026-10-25 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

Daily 2026-10-25 Nextcloud Collabora CODE CVE-2026-110447 Exploitation Priority Update

1. Executive Summary

CVE-2026-110447 affects the optional Collabora Online Built-in CODE Server application for Nextcloud (`richdocumentscode`) before version 26.4.303. NVD describes OS command injection in `proxy.php` when the built-in CODE server is not running, such as after a restart; it explicitly distinguishes this from standalone Collabora Online deployments. CISA's KEV catalog identifies the vulnerability as actively exploited. This makes internet-facing Nextcloud instances that use the built-in CODE app an immediate patch-and-hunt priority.

The remediation task is precise: determine whether `richdocumentscode` is installed and enabled, differentiate it from standalone Collabora architecture, update the app to the fixed version through the approved Nextcloud process, and examine the server for unauthorized files and web-worker execution during the exposure period. Do not equate any Nextcloud deployment with exposure. The source set supports the version and deployment preconditions; it does not prove compromise of a given organization.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-110447
Component	Collabora Online Built-in CODE Server / Nextcloud `richdocumentscode` app
Vulnerability class	OS command injection in `proxy.php`
Affected scope	Built-in CODE Server before 26.4.303; standalone Collabora Online is not affected according to NVD
Trigger condition	The built-in CODE server is not running, for example after restart
Published / updated	14 October 2026 / 24 October 2026 (NVD)
Exploitation status	Listed by CISA KEV; public sources describe exploitation in September and October 2026

3. Source Review & Confidence

Source	Contribution	Confidence
CISA KEV	Active-exploitation priority	High
NVD CVE record	Architecture, version, and trigger-condition detail	High
GitHub Advisory GHSA-f97p-r72q-64h2	Fixed version and upstream advisory context	High
Nextcloud community update	Supporting administrator remediation context	Medium

The core technical claims are corroborated by NVD and the GitHub advisory. CISA KEV establishes defender priority. The report does not assert a named actor, broad victimology, or a universal web-shell filename because those claims require tenant-specific evidence.

4. Vulnerability Details

The vulnerable component is not Nextcloud core or a standalone Collabora server. It is the bundled Collabora Online Built-in CODE Server app, commonly installed as `richdocumentscode`. NVD states that `proxy.php` can be reached when the CODE server is unavailable and the affected implementation permits OS command injection. The resulting impact is remote code execution on an exposed Nextcloud host under the relevant service context. Since restart state is material, change windows and service interruptions are useful pivots for retrospective investigation.

5. Attack Scenarios

- An internet-facing Nextcloud instance with the vulnerable app restarts; an attacker targets the application endpoint while the built-in CODE server is unavailable.
- An attacker probes exposed collaboration services for the optional app, then uses command execution to stage scripts, alter files, or establish a web shell.
- A patch removes the application flaw, but an earlier compromise persists through unauthorized PHP content, modified app files, scheduled tasks, or service-account keys.

6. Threat Landscape & Exploitation Status

CISA KEV status means exposed instances should be treated as both a patching and incident-hunting priority. The public record supports exploitation concern, but it is not sufficient to state that all unpatched instances are compromised. Preserve access, web, PHP-FPM/Apache/Nginx, file-integrity, authentication, and endpoint telemetry before deleting suspicious files or applying broad cleanup.

7. Affected Products and Exposure

Exposure pattern	Priority	Defender action
Internet-facing Nextcloud with `richdocumentscode` below 26.4.303	Critical	Patch immediately and conduct post-exposure review
Built-in CODE Server behind VPN but broadly accessible	High	Patch on expedited schedule; examine admin/access logs and segmentation
Standalone Collabora Online integration	Verify	Confirm architecture; NVD says this CVE does not affect standalone servers
Nextcloud without `richdocumentscode`	Verify	Record negative exposure evidence; do not apply unneeded emergency changes

8. Mitigation and Workarounds

1. Inventory all Nextcloud deployments and identify the installed/enabled `richdocumentscode` version; verify through the application inventory rather than documentation alone.
2. Update the Built-in CODE Server app to version 26.4.303 or later following approved vendor guidance.
3. Restrict Nextcloud administration and application endpoints to trusted paths while patching; ensure MFA and logging are enabled.
4. Search the app directory, web roots, temporary directories, and scheduled-task locations for unrecognized PHP/script files or unexpected ownership/timestamps.
5. Review post-restart requests, failed service launches, administrative logins, PHP worker child processes, and outbound connections for the exposure window.
6. Rotate application/service credentials and invalidate suspicious sessions when evidence indicates unauthorized access.

9. Detection Engineering

Signal	Telemetry	Analytic goal
Web/PHP process spawning a shell, downloader, or interpreter	EDR process telemetry	Detect command-injection follow-on activity
New or modified PHP beneath Nextcloud/app/temp locations	FIM, EDR file telemetry	Identify web-shell or payload staging
Request burst near CODE service restart/unavailability	Reverse proxy, web server, service logs	Identify exploitation probing around the stated precondition

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ ("php-fpm", "apache2", "httpd", "nginx")
| where FileName in~ ("sh", "bash", "dash", "curl", "wget", "python", "perl")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName
| order by Timestamp desc
```

10. Threat Hunting

Hypothesis: Exploitation of the built-in CODE Server flaw may create suspicious web-worker process lineage or write script content near the Nextcloud application tree following a restart/service failure.

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("/apps/richdocumentscode/", "/nextcloud/", "/var/www/")
| where FileName endswith_cs ".php" or FileName endswith_cs ".phtml" or FileName endswith_cs ".phar"
| project Timestamp, DeviceName, FolderPath, FileName, InitiatingProcessFileName,
InitiatingProcessAccountName
| order by Timestamp desc
```

Triage hits against approved application deployments and change records. These queries detect possible follow-on behavior, not the exploit request itself.

11. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Applicable to exposed Nextcloud service hypothesis
T1059	Command and Scripting Interpreter	Relevant command-injection execution behavior
T1505.003	Web Shell	Follow-on persistence hunt target, not assumed compromise

12. Validation / Lab Testing

No exploit was executed and no Nextcloud system was scanned. The report is source-backed and detection content was reviewed as an analyst query pattern. Validate package/app version and service behavior through approved administration and a representative non-production test where possible.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Collaboration platform owner	Identify `richdocumentscode` instances and

		update to 26.4.303 or later
Critical	SOC/IR	Preserve and review web, PHP, file-integrity, and process telemetry
High	Infrastructure	Correlate restart/service-failure events with unusual requests and changes
High	IAM	Review administrator/session/service credential exposure and rotate where indicated

14. References

See `sources.md` and `references.md` for the reviewed source set and limitations.